

One name. Two different files.

Race-condition vulnerability lab

A race condition is timing-dependent. Here the target changes between check and use.

MECHANISM → LIVE TERMINALS → FINDINGS → DEFENCES

Where the race lives

The pathname stays the same; the object reached through it can change.

CHECK

```
access ("/tmp/XYZ", W_OK)
```

Attacker switches the symlink here

USE

```
fopen ("/tmp/XYZ", "a+")
```

Real UID: 1000 (seed)

The permission check uses the ordinary caller.

Effective UID: 0

The Set-UID victim supplies root authority to the open.

Lab prerequisite: deliberately installed root-owned Set-UID victim; attack controls set to 0/0.

What to watch in the live demo

Switch to the two terminals now. Explain the output as it appears.

A — Attacker

First: XYZ → /dev/null

Then: XYZ → /etc/passwd

B — Victim and results

Check passed

Inspect the complete record

Non-sudo login → id

Task 2.A: an explicit artificial 10-second delay for explanation.

Read the output in the right order

The proof is the full chain, not a successful-looking message.

uid=1000(seed)

The attack starts as an ordinary user.

Exact seven-field test record

The chosen account entry reached
/etc/passwd.

su - test → id: uid=0(root)

That non-sudo login actually obtained root
authority.

A changed SHA-256 is a signal to inspect — not proof of root access.

The no-delay experiment also succeeded

Recorded measurements from 3 October 2026 — a live run can differ.

Recorded run	Attempts	Wall time	Verified
Naive: first success	20	0.865 s	UID 0
Atomic exchange	1	0.273 s	UID 0
Naive: recorded repeat	1	0.238 s	UID 0

Same no-delay vulp. Bash timer: whole seconds; a 0 s reading does not mean zero runtime.

Live demonstration: original vulp + atomic switching, with no artificial delay.

Why the naive attacker got stuck

File exists and Operation not permitted explained a real failure.

1 `unlink()`

XYZ is temporarily absent.

2 `fopen("a+")`

The victim can create a root-owned regular file.

3 Sticky `/tmp`

seed cannot unlink that root-owned entry.

Observed: root:seed, mode 0664, under root-owned mode-1777 `/tmp`.

RENAME_EXCHANGE removes this missing-name gap — it does not fix the victim.

Two defences, tested independently

The long trials are recorded findings; the live check is a short control.

Least privilege

vulp_least • controls 0/0

9,455 attempts / 300 s

Target hash unchanged

Protected operation denied

Ordinary-file write succeeded

Symlink protection

original vulp • controls 1/0

9,177 attempts / 300 s

Target hash unchanged

Stable privileged open denied

Ownership/context rule applies

Observed: no protected-file change in either 300-second trial.

Protect the operation, not just the filename

A local file-handling flaw can undermine the account database used by authentication.

Use the right privilege

Drop privilege before user-directed file operations.

Use the opened object

Open once; retain and validate the file descriptor.

Create files safely

Use `mkstemp`, `O_CREAT|O_EXCL` and trusted directories.

Do not check an attacker-changeable name and later use it with more privilege.

After the demo: exit root, stop processes, restore the baseline and remove Set-UID (Part 4).

Recorded verification: account and UID

Actual image excerpts; whole originals are retained as S09.

Complete-record check

```
+ grep -n "^test:" /etc/passwd
51:test:U6aMy0wojraho:0:0:test:/root:/bin/bash
Exact input record count: 1; fields: 7; UID=0; GID=0
Home=/root; shell=/bin/bash; record length=43
+ getent passwd test
test:U6aMy0wojraho:0:0:test:/root:/bin/bash
```

Actual non-sudo command and UID output (separate excerpts)

```
seed@VM [B:lab-files]$ python3 ../automation/verify-record.py && su - test
```

```
uid=0(root) gid=0(root) groups=0(root)
root
root@VM [B:verified-login]#
```

What the failures and timers mean

Preserved outcomes matter as much as the successful screenshots.

Original naive log

Last progress 76,000 / 227 s; final totals unknown.

Naive retry 1

9 attempts; 0 integer seconds; sticky-file failure.

Supplemental capture run

2 attempts; 0 integer seconds; sticky-file failure.

Integer timer

0 seconds means below the timer's granularity.

Runner wall time

Includes monitor startup/exit; not the race-window size.

Live-demo recovery

Use the real output; keep the experiment boundary clear.

**Timing miss / 30 s
unchanged**

State the failed bounded attempt. Use the labelled recorded S09/S11 result.

File exists / unlink denied

Stop first. Inspect /tmp and XYZ ownership. Preserve the failure; reset in B.

Root shell still open

exit once, then id. Return to seed before reset or a new ordinary-user trial.

Set-UID missing

Use Part 0 setup. Do not run the attacker or victim through sudo.

Sources and supporting files

Original lab content and actual experimental evidence are distinguishable.

Wenliang Du / SEED Labs — Race Condition Vulnerability Lab (2006–2020)

seedsecuritylabs.org/Labs_20.04/Software/Race_Condition/

Linux kernel filesystem sysctl documentation; `access(2)`, `rename(2)`, `open(2)`

Supplied Member 5 allocation and our VM logs / S01–S15 evidence

REPORT.pdf: analysis and full results **LIVE_DEMO.pdf: exact A/B command order**

CC BY-NC-SA 4.0 attribution retained. AI-assisted orchestration/document preparation is disclosed in the report.